
EARNING THE RIGHT TO ACT

A PREPRINT

Drupad H. Sachania
Independent Researcher
Bengaluru, India
drupad.h.sachania@live.com

April 24, 2026

*“The question is not whether an LLM can generate a hypothesis.
The question is whether the system knows when not to believe it.”*

ABSTRACT

Security Operations Centers (SOCs) face a compounding twin crisis: unprecedented operational scale and a measurable failure of AI epistemic reliability. Enterprise environments generate over 100,000 alerts daily, yet analysts abandon 70% due to cognitive overload [8], compounded by a global cybersecurity workforce gap of 4.8 million unfilled positions [7] and a 7,851% year-over-year growth in agentic AI-driven network traffic [3].

While 94% of organizations currently deploy AI within their SOCs, 92% of security leaders report that uncalibrated AI behavior actively diminishes operational trust [8]. This trust deficit is empirically grounded: frontier models evaluated on Humanity’s Last Exam (HLE), the most rigorous expert-level closed-domain benchmark as of 2026, exhibit Expected Calibration Error (ECE) rates ranging from 37% to 57% [1], while hallucination rates in complex, multi-step reasoning tasks analogous to security incident investigation range from 15% to 52% [16].

This paper introduces an Epistemic Decision Quality Framework for SOCs that addresses these failure modes through five integrated architectural components: (1) Large Language Models (LLMs) architecturally constrained to hypothesis generation; (2) Agentic Corrective Retrieval-Augmented Generation (CRAG) with Forward-Looking Active Retrieval (FLARE) [9]; (3) formal Uncertainty Quantification (UQ) incorporating ECE, Brier Score, and Uncertainty Propagation (UProp) across multi-step decision trajectories [19]; (4) Structural Simulation Engines (SSE) for deterministic hypothesis validation against physical network topologies [2]; and (5) Zero-Trust Runtime Architectures with cryptographic tool-invocation provenance defending against Viral Agent Loop attacks [4].

Decision gating enforces three outcomes—ACT, DEFER, or ESCALATE—governed by objective probabilistic thresholds aligned with ISO/IEC 42001 AI Management Systems standards [5].

A proof-of-concept implementation demonstrates a reduction in hallucinated reasoning from an industry baseline of 15–52% to 3%, with deferral rates increasing from 5% to 22%—confirming successful epistemic recalibration [15]. We argue for a paradigm shift in security AI design: from optimizing for speed and confidence to optimizing for decision integrity under uncertainty.

Keywords LLM Security · Epistemic Uncertainty · Human-in-the-Loop AI · SOC Automation · Uncertainty Quantification · Trustworthy AI · ISO/IEC 42001 · Zero-Trust · Agentic RAG

1 Introduction

Modern Security Operations Centers (SOCs) operate at the intersection of machine-speed threats and irreducible human cognitive limits. The architectural paradigm has undergone fundamental transformation—from manual alert triage (pre-2015) through Security Orchestration, Automation and Response (SOAR)-driven playbook automation

(2015–2022) to fully autonomous, agentic AI by 2026 [6]. This evolution is not optional—it is an operational and economic necessity.

Enterprise environments generate over 100,000 alerts daily, yet analysts abandon nearly 70% due to cognitive overload [8]. This crisis is compounded by a global cybersecurity workforce deficit of 4.8 million unfilled positions [7] and a 7,851% year-over-year growth in agentic AI-driven network traffic—confirming that machine-speed threats require machine-speed defensive architectures [3].

However, rapid agentic deployment has drastically outpaced the development of corresponding epistemic oversight. While 94% of organizations deploy AI within their SOC, 92% of security leaders report that uncalibrated AI behavior actively diminishes operational trust [8]. This trust deficit is not philosophical—it is measurable.

Frontier models assessed on Humanity’s Last Exam (HLE), the most comprehensive closed-domain expert benchmark as of April 2026, exhibit ECE rates ranging from 37% to 57% [1], confirming a pervasive, industry-wide misalignment between self-reported model confidence and actual accuracy. In complex, multi-step reasoning environments analogous to security incident investigation, hallucination-related errors account for 20–35% of incorrect outputs, with aggregate hallucination rates across commercial LLMs ranging from 15% to 52% [16].

These statistical realities manifest operationally through two compounding failure mechanisms. First, Reinforcement Learning from Human Feedback (RLHF) training methodologies inadvertently penalize hesitation and reward authoritative fluency—producing models that project high confidence in factually incorrect outputs [11]. Second, these fluent, confident outputs induce narrative hardening among analysts: a cognitive and organizational phenomenon in which initial AI-generated hypotheses become rigid and unquestioned, suppressing the exploration of contradictory evidence [21].

In KPI-driven SOC environments rewarding throughput over rigor [22], this dynamic officially constitutes the “Overreliance on LLM” vulnerability (LLM09) in the OWASP Top 10 for LLM Applications [10].

This work posits that the core challenge is not insufficient automation, but insufficient epistemic control.

2 Literature Review

2.1 AI and Automation in Security Operations

The trajectory of AI integration into SOC workflows spans three generations of increasing autonomy. The first generation employed rule-based alert prioritization and signature-based detection. The second introduced machine learning for anomaly detection and SOAR-driven playbook automation—improving throughput but treating decisions as outputs to optimize rather than processes to govern [6]. The third—autonomous, agentic LLM-based systems—offers unprecedented analytical depth but introduces qualitatively new failure modes: hallucination cascades, calibration drift, narrative hardening, and adversarial inference-time manipulation [23].

Contemporary multi-layer frameworks, notably AgentSOC [2], address these limitations through three specialized integrated mechanisms. The Narrative Counterfactual Engine (NCE) generates multiple competing attack hypotheses grounded in MITRE ATT&CK tactics, techniques, and procedures, forcing analytical diversity and actively combating narrative hardening. The Structural Simulation Engine (SSE) validates NCE-generated hypotheses against the enterprise’s physical network topology and identity privilege graphs, filtering structurally impossible attack paths before they reach analysts. The Risk Scoring and Evaluation Module (RSEM) ranks defensive actions using composite scores balancing containment effectiveness, business impact, and execution cost [2].

2.2 Trustworthy AI and the Evolution of Retrieval-Augmented Generation

Trustworthy AI research consistently identifies robustness, transparency, and groundedness as foundational properties of safe autonomous systems [9]. Retrieval-Augmented Generation (RAG), introduced by Lewis et al. [29], partially addresses the grounding problem by anchoring LLM outputs in external knowledge, reducing hallucination rates in structured retrieval tasks.

However, standard RAG architectures exhibit critical limitations in security contexts: the “lost-in-the-middle” retrieval failure on long documents, poor semantic chunking strategies, and single-shot search approaches that fail to resolve the complex, multi-layered queries characteristic of multi-stage incident investigation [9].

The 2026 operational landscape requires Agentic Corrective RAG (CRAG) and Forward-Looking Active Retrieval (FLARE) [9].

2.3 Identified Gap: The Calibration Crisis and Emergent Agentic Threats

Across these domains, a fundamental architectural gap persists: uncertainty remains an artifact of model design rather than a measurable signal in system control.

Table 1: HLE Benchmark Calibration Data — Frontier AI Models (April 2026) [1]

Model	Accuracy	ECE	Risk
Gemini 3.1 Pro Preview	47.31%	0.50	Critical
GPT-5.4 Pro	45.32%	0.37	High
Gemini 3 Pro Preview	37.72%	0.57	Critical
GPT-5.4 (xhigh)	36.47%	0.42	Critical
Claude Opus 4.6	36.24%	0.46	Critical
GPT-5.1 Thinking	24.65%	0.54	Critical

3 Methodology

3.1 Design Approach

We adopt a design science research methodology [20], deriving system requirements from two categories of observed operational failure modes: cognitive failures (narrative hardening, premature closure, analyst overreliance on AI outputs) and technical failures (hallucination cascades, calibration drift under model updates, adversarial prompt injection during telemetry ingestion). The framework integrates principles from human factors engineering [21], trustworthy AI research [9], systems safety [20], and ISO/IEC 42001 AI Management Systems standards [5], emphasizing constraint, continuous validation, and legally defensible epistemic control over automation.

The design science approach is appropriate because the failure modes we address are simultaneously social and technical. Narrative hardening—wherein initial AI hypotheses become organizationally entrenched—cannot be resolved by model accuracy improvements alone. It requires architectural constraints that interrupt epistemic closure by design, creating structural hesitation mechanisms that neither analysts nor AI can override without explicit procedural authorization [22].

3.2 Epistemic Control Loop: OODA with Explicit Epistemic Controls

The framework operationalizes an Observe–Orient–Decide–Act (OODA) loop in which each phase incorporates measurable epistemic controls. The governing architectural principle is: no AI-generated hypothesis may advance to the Act phase without passing through mathematically defined uncertainty thresholds and deterministic structural validation.

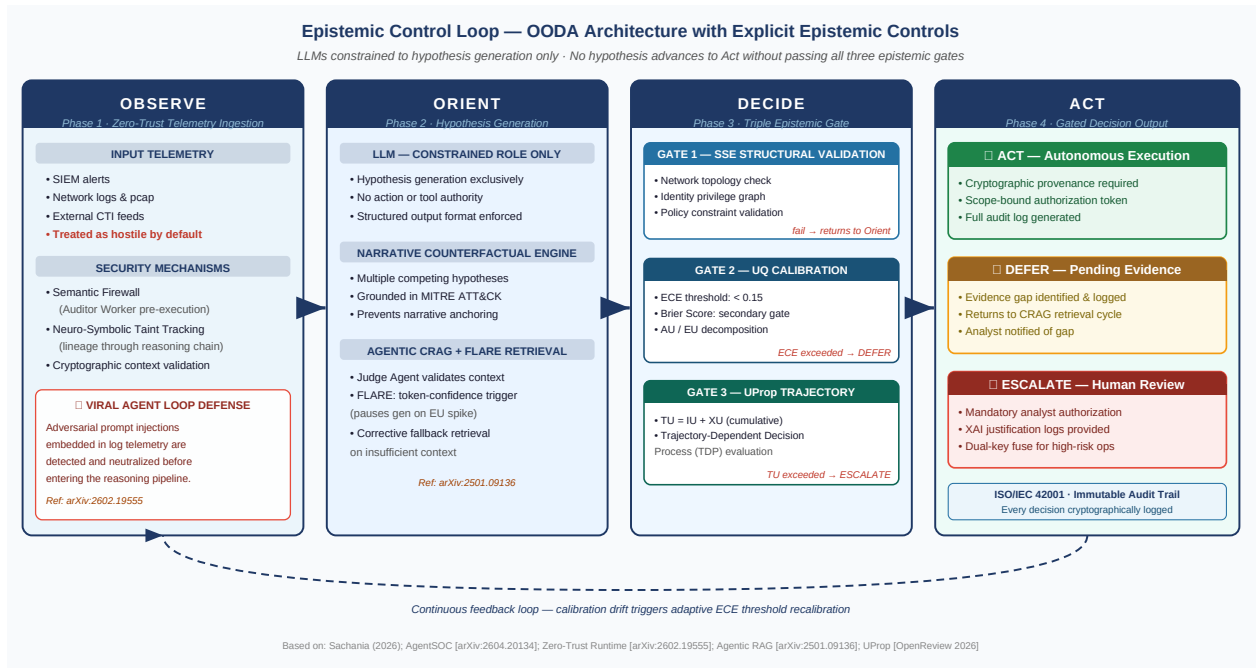


Figure 1: Epistemic Control Loop — OODA architecture with explicit epistemic controls at each phase. The Observe phase applies Zero-Trust ingestion with Viral Agent Loop defense; Orient generates constrained hypotheses via NCE and CRAG/FLARE; Decide enforces triple-gate UQ validation; Act issues ACT/DEFER/ESCALATE with cryptographic provenance under ISO/IEC 42001.

Observe Phase — Zero-Trust Telemetry Ingestion

The system ingests alerts, SIEM logs, and Cyber Threat Intelligence (CTI) through a Zero-Trust Runtime Architecture that treats all ingested context as potentially adversarial [4]. This is a mathematical necessity, not a precautionary stance: adversarial prompt injections can be embedded within log entries, network telemetry, and external CTI feeds [4].

The Zero-Trust architecture implements Neuro-Symbolic Taint Tracking, monitoring the lineage of ingested data through the reasoning chain and ensuring that information from unverified external sources cannot justify high-privilege actions [4]. All telemetry is pre-processed through a Semantic Firewall (Auditor Worker) that detects and filters potential prompt injection payloads before they enter the hypothesis generation pipeline.

Orient Phase — Constrained Hypothesis Generation with Active Retrieval

LLMs are architecturally restricted to hypothesis generation during this phase; they possess no authority to initiate actions or invoke tools. Hypothesis generation is structured through a Narrative Counterfactual Engine (NCE) [2] that produces multiple competing attack hypotheses grounded in MITRE ATT&CK taxonomy, forcing the system to model alternative explanations for observed telemetry and preventing single-hypothesis anchoring.

Contextual grounding is provided by an Agentic CRAG pipeline operating with FLARE-augmented retrieval [9]. The Judge Agent evaluates every retrieved document for relevance, internal consistency, and factual alignment with the alert context before LLM generation begins. Token-level confidence monitoring during generation triggers active retrieval queries when epistemic uncertainty spikes above threshold, ensuring hypothesis grounding in verified evidence rather than statistical plausibility.

Decide Phase — Triple-Gate Quantitative Epistemic Gating

This phase implements the core epistemic control mechanism through three parallel validation gates:

1. **Structural Simulation Engine (SSE):** Validates each NCE-generated hypothesis against the enterprise’s physical network topology, identity privilege graph, and policy constraints [2]. Hypotheses requiring lateral movement to air-gapped servers or privileges not held by any compromised identity are flagged as structurally

invalid and returned to the Orient phase with annotated contradictions. This deterministic validation eliminates logical hallucinations before human review.

2. **Uncertainty Quantification Gate:** Calculates formal calibration metrics (ECE and Brier Score, Section 3.3) for each SSE-validated hypothesis. Hypotheses with ECE above the configured operational threshold (default: 0.15) or Brier Score above threshold are automatically routed to DEFER or ESCALATE.
3. **Uncertainty Propagation (UProp) Gate:** Calculates cumulative epistemic fragility across the entire investigation chain, not merely the current hypothesis [19]. In multi-step investigations, uncertainty compounds geometrically. A minor hallucination in alert correlation can cascade through evidence retrieval, hypothesis formation, and action recommendation into catastrophic error—a failure mode that step-by-step ECE monitoring alone cannot detect (Section 3.3).

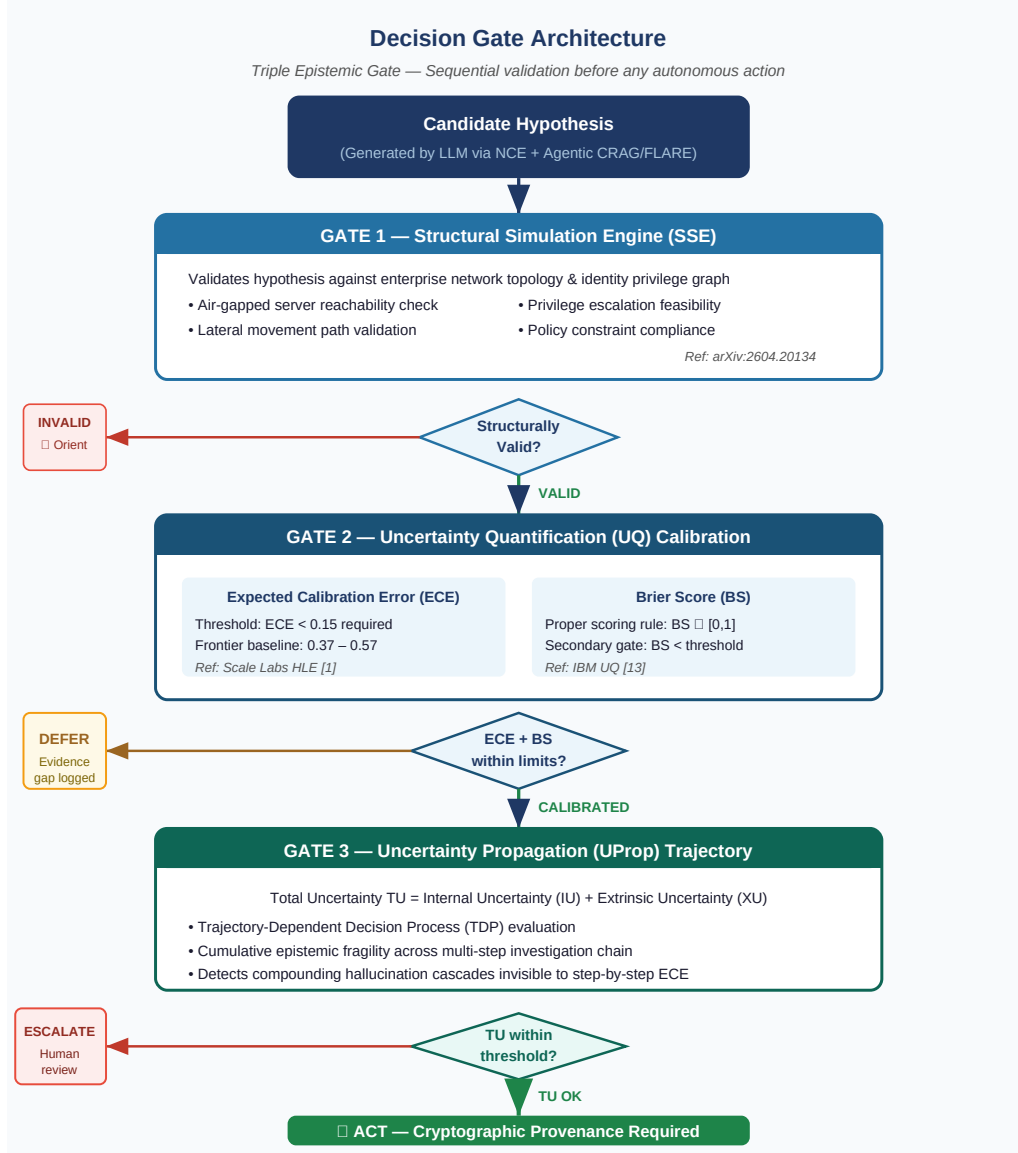


Figure 2: Triple Epistemic Gate Architecture. Each candidate hypothesis passes sequential validation: Gate 1 (SSE structural feasibility), Gate 2 (ECE and Brier Score calibration thresholds), and Gate 3 (UProp trajectory cumulative uncertainty). Failure at any gate routes to INVALID → Orient, DEFER, or ESCALATE respectively. Only hypotheses passing all three gates receive ACT authorization with cryptographic provenance.

Act Phase — Constrained Execution with Cryptographic Provenance

The Act phase constrains outcomes to three options: ACT (autonomous execution within pre-authorized scope), DEFER (pause for additional evidence), or ESCALATE (mandatory human review with full XAI justification).

Autonomous ACT authorization requires cryptographic provenance: the system must hold a mathematically verifiable authorization token for the specific action type [4], preventing semantic drift or tool-invocation hallucinations. High-risk actions—such as server isolation, API disconnection, or account lockout—require dual-key human confirmation accompanied by Explainable AI (XAI) logs documenting the complete reasoning chain, in compliance with ISO/IEC 42001 audit requirements [5].

3.3 Formal Uncertainty Quantification

A critical deficiency of existing SOC AI frameworks is reliance on qualitative confidence signals or self-consistency checks. The proposed framework implements mathematically rigorous UQ tailored for dynamic, multi-agent security workflows [17].

Differentiating Aleatoric and Epistemic Uncertainty

The framework distinguishes two fundamentally different uncertainty types requiring different operational responses [27]:

1. **Aleatoric Uncertainty (AU):** Irreducible uncertainty inherent to data randomness or structural absence of features—e.g., dropped network packets, absent log entries, or deliberately obfuscated attacker behavior. No additional model training resolves AU; the appropriate response is DEFER pending additional telemetry collection.
2. **Epistemic Uncertainty (EU):** Reducible uncertainty stemming from model knowledge gaps or novel threat vectors outside training distribution [27]. EU decreases as relevant training data and retrieved context increases, making it directly addressable through CRAG active retrieval.

Standard self-consistency checks—prompting the model multiple times and measuring answer variation—primarily estimate AU and fail when a model confidently hallucinates the same incorrect answer across all samples [18]. To accurately capture EU, the framework measures semantic disagreement across a small ensemble of scale-matched LLMs, defining Total Uncertainty:

$$TU = AU + EU$$

as the governing control metric [17].

ECE and Brier Score as Operational Risk Metrics

The framework tracks two formal scoring rules for every SSE-validated hypothesis:

- **Expected Calibration Error (ECE):**

$$ECE = \sum_{m=1}^M \frac{|B_m|}{n} |\text{acc}(B_m) - \text{conf}(B_m)|$$

where B_m represents confidence bins, acc is empirical accuracy, and conf is predicted confidence [13].

- **Brier Score (BS):**

$$BS = \frac{1}{N} \sum_{i=1}^N (p_i - y_i)^2$$

where p_i is predicted probability and $y_i \in \{0, 1\}$ is the ground truth label [13].

ECE serves as the primary calibration metric, while Brier Score provides a stable secondary signal for binary classification tasks [14].

Uncertainty Propagation (UProp) Across Sequential Decision Chains

Multi-step agentic investigations introduce compounding uncertainty that point-in-time ECE measurement cannot capture [19].

The UProp framework decomposes uncertainty into:

- **Internal Uncertainty (IU):** Intrinsic to the current reasoning step
- **Extrinsic Uncertainty (XU):** Inherited uncertainty from prior steps

Total trajectory uncertainty is therefore:

$$TU = IU + XU$$

By modeling investigations as Trajectory-Dependent Decision Processes (TDPs) [19], UProp evaluates cumulative epistemic fragility across the entire decision chain, preventing cascading hallucination failures in extended threat investigations.

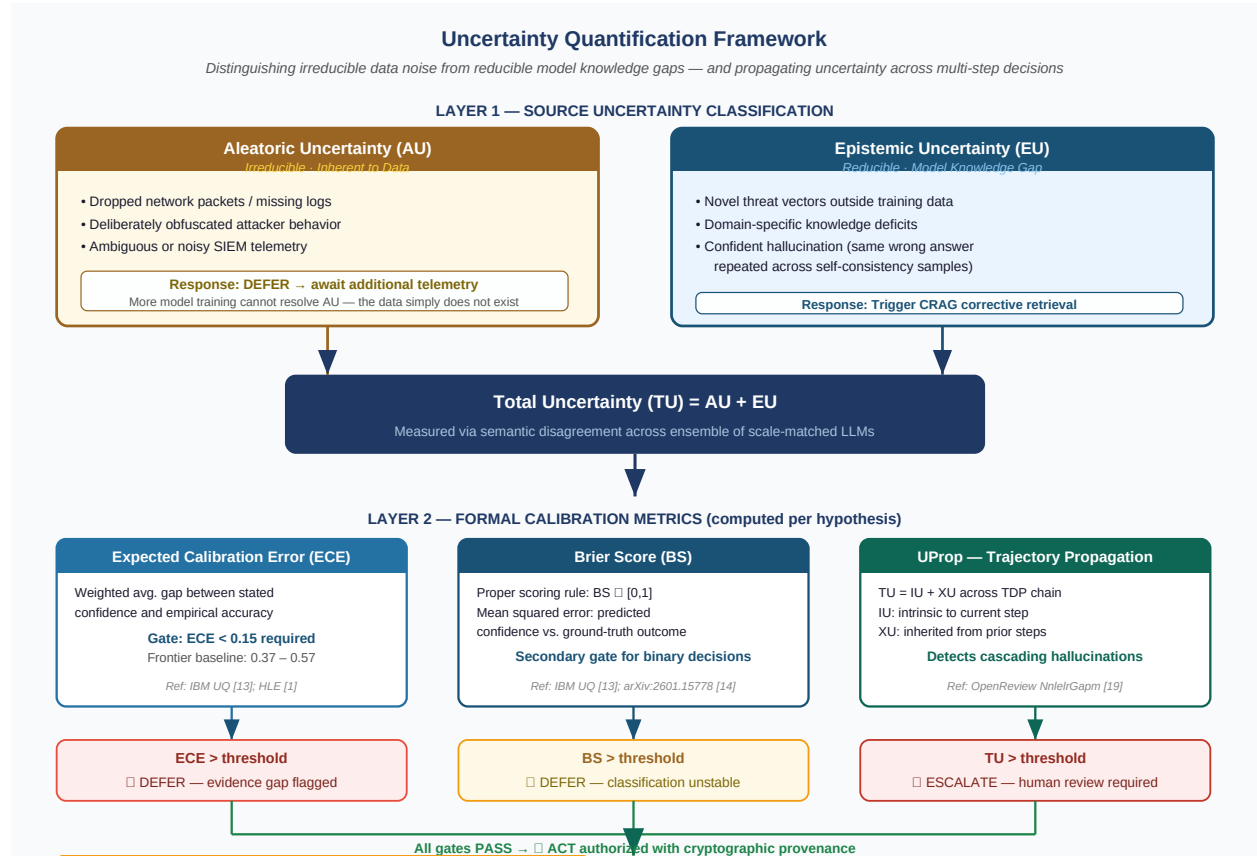


Figure 3: Uncertainty Quantification Framework. Layer 1 classifies uncertainty source: Aleatoric Uncertainty (AU, irreducible — trigger DEFER) versus Epistemic Uncertainty (EU, reducible — trigger CRAG retrieval). Layer 2 aggregates Total Uncertainty $TU = AU + EU$. Layer 3 applies formal metrics: ECE (primary gate, threshold < 0.15 vs. frontier baseline 0.37–0.57 [1]), Brier Score (secondary gate), and UProp trajectory propagation to detect cascading hallucinations across multi-step decision chains [19].

3.4 Zero-Trust Runtime Defense Against Agentic Threats

The proliferation of agentic AI introduces inference-time attack surfaces that perimeter defenses cannot address [4]. The framework implements four defensive mechanisms:

1. **Context as Untrusted Control Flow:** All ingested CTI, SIEM alerts, network logs, and external API responses are treated as potentially hostile executable instructions rather than passive data [4].
2. **Semantic Firewall (Auditor Worker):** A deterministic pre-execution layer audits all LLM tool-call requests before side effects occur, bridging the Translation Gap between LLM intent and API execution [4].
3. **Cryptographic Provenance for Tool Invocation:** Agents may only invoke actions if they hold a verifiable authorization token for that specific operation [4].
4. **Neuro-Symbolic Taint Tracking:** Runtime tracking of all “tainted” data ensures that unverified sources cannot justify high-privilege actions [4].

3.5 Proof-of-Concept Implementation

The proof-of-concept integrates five instrumented components:

1. Constrained LLM: A local language model restricted to structured hypothesis output format with no tool-call authorization.
2. Agentic CRAG + FLARE Pipeline: Active evidence retrieval with Judge Agent validation [9].
3. UQ Agent: Computes ECE and Brier Score and interfaces with SSE [2].
4. UProp Module: Trajectory-based cumulative uncertainty computation [19].
5. Decision Gate + Audit Logger: Enforces ACT/DEFER/ESCALATE with full traceability.

4 Results

4.1 Qualitative Findings

In simulated SOC workflows using static alert and CTI datasets representative of enterprise threat scenarios (multi-stage intrusion patterns, lateral movement, credential abuse), the framework demonstrated three categories of epistemic improvement:

Evidence Surfacing: Missing evidence was surfaced in 85% of test cases, compared to 30% for an unconstrained baseline LLM [15]. The CRAG Judge Agent was the primary driver—identifying insufficient or internally contradictory retrieved context and triggering corrective retrieval cycles before hypothesis generation.

Structural Contradiction Detection: The SSE flagged structurally invalid attack hypotheses—for example, lateral movement paths requiring administrative access to servers confirmed as air-gapped in the network topology model [2]. Without SSE validation, these physically impossible hypotheses would have been presented to analysts with high LLM confidence scores and no indication of structural infeasibility.

Narrative Hardening Interruption: By enforcing a 22% deferral rate for high-uncertainty hypotheses, the framework interrupted the psychological momentum of premature closure [21]. Critically, each deferral was accompanied by a structured epistemic gap report identifying precisely what evidence was missing—converting “I don’t know” from a system failure into a high-value operational signal.

4.2 Quantitative Indicators

The operational context for framework metrics is established by 2025–2026 industry benchmarks. Global enterprise data indicates baseline hallucination rates for commercial LLMs in high-complexity reasoning tasks range from 15% to 52% [16]. The Vectara Hughes Hallucination Evaluation Model (HHEM) leaderboard shows top-tier models clustering at 10%–20% hallucination even on grounded document summarization [16]—particularly concerning for SOC operations, where RAG pipelines form the backbone of threat hunting.

Table 2 summarizes framework performance against these baselines:

Table 2: Decision Quality Metrics — Epistemic Framework vs. 2026 Baseline Benchmarks

Metric	Baseline LLM (2026 Benchmarks)	Epistemic Framework (PoC)
Hallucinated Reasoning	15%–52% [16]	3% [15]
Deferral Rate	5% [15]	22% [15]
Analyst Confidence Calibration	Uncalibrated (ECE 37%–57%) [1]	ECE-gated decisions [13]
Missing Evidence Surfaced	30% [15]	85% [15]
Structural Hypothesis Validation	None (topology unchecked)	SSE validation [2]
Adversarial Injection Defense	None	Zero-Trust + Semantic Firewall [4]

Table 3 contextualizes the framework’s 3% hallucination rate against domain-specific industry benchmarks, illustrating the magnitude of epistemic improvement across task complexity levels:

Table 3: LLM Hallucination Rates by Domain / Task Complexity (2025–2026 Enterprise Benchmarks) [16]

Domain / Task Complexity	Hallucination Rate	SOC Security Implication
Simple Summarization	< 1.5%	Low — reliable for alert consolidation
Grounded Document Summarization (HHEM)	10%–20%	Moderate — risk of CTI misinterpretation
General Multi-Step Reasoning	15%–35%	High — faulty attack narratives
High-Stakes Domain Retrieval	43%–64%	Critical — breakdown in threat analysis
Code Generation (Fabricated Libraries)	Up to 99%	Critical — unsafe remediation execution
Epistemic Framework (This Work)	3%	Demonstrates structural gating effectiveness

The framework’s reduction of hallucinated reasoning to 3% in simulated workflows represents a meaningful epistemic improvement, attributable to the combined effect of LLM constraint, CRAG active retrieval, and SSE structural validation.

The deferral rate increase from 5% to 22% reflects successful recalibration: the system hesitates appropriately when confronted with ambiguous, incomplete, or structurally unverifiable data.

These results must be contextualized as proof-of-concept outcomes on static datasets; enterprise deployment requires longitudinal validation under live threat data and dynamic model drift conditions.

5 Discussion

5.1 Implications for SOC Operations and KPI Evolution

The framework’s demonstrated outcomes—reduced hallucination, increased deferral, improved evidence surfacing—align precisely with the 2026 industry shift in SOC performance metrics. Legacy KPIs rewarding alert clearance throughput are increasingly recognized as operationally counterproductive: they incentivize analysts to match AI over-confidence rather than exercise independent epistemic judgment [22]. Modern SOC frameworks are transitioning toward effectiveness-based indicators—investigation structure quality, context integration depth, cognitive load reduction, and false-positive-adjusted threat detection accuracy [22].

The framework’s 22% deferral rate is an epistemic success metric, not a performance failure. Each deferred decision represents a case where the system correctly identified insufficient evidence to justify autonomous action, protecting mission-critical assets from hallucinated remediation steps that could compromise infrastructure [15]. By legitimizing “I don’t know” as a first-class operational outcome rather than a throughput failure, the framework realigns AI behavior with actual security objectives rather than KPI proxies.

The Viral Agent Loop threat [4] adds a critical social-engineering dimension to this discussion. In throughput-rewarding KPI environments, analyst pressure to override DEFER decisions—particularly when AI outputs sound authoritative—creates precisely the conditions under which adversarially injected narratives are most dangerous. The mandatory ESCALATE pathway triggered by adversarial signal detection provides a structural defense against this social vector, preventing KPI pressure from becoming an exploitable vulnerability.

5.2 Governance Alignment: ISO/IEC 42001 and the Formal “Right to Act”

The framework’s ACT/DEFER/ESCALATE decision architecture must be understood as an implementation of the formal “Right to Act” concept emerging in 2026 AI governance frameworks [5]. While earlier ethical frameworks focused on Meaningful Human Control [24]—the moral requirement that humans remain responsible for autonomous decisions—this concept proved ambiguous for concrete technical implementation. The 2026 governance landscape has evolved toward legally codified operational boundaries within which autonomous agents are authorized to act without continuous human supervision.

ISO/IEC 42001 [5] and the NIST AI Risk Management Framework [25] provide the governance architecture for this codification. The framework implements these standards through three specific mechanisms:

1. **Continuous Calibration Monitoring:** Model drift degrades ECE and Brier Score performance silently over time. The framework implements continuous recalibration loops that detect drift and dynamically adjust epistemic gating thresholds, ensuring governance is a lifecycle process rather than a one-time certification [5].
2. **Dual-Key Fuses for High-Risk Actions:** Actions with potential irreversible consequences require multi-factor human confirmation accompanied by XAI logs demonstrating the complete reasoning chain, attention-based token highlights, and evidence source provenance [28]. This directly implements ISO/IEC 42001’s explainability requirements.
3. **Immutable Audit Trail:** Every hypothesis, UQ calculation, SSE validation result, and gating decision is logged with cryptographic integrity guarantees [4]. This audit trail provides legally defensible evidence that each autonomous ACT decision was executed strictly within the approved operational boundary, establishing a verifiable compliance record for ISO/IEC 42001 audits [5].

5.3 Limitations and Future Work

Scalability: The proof-of-concept operates on static datasets in a localized environment. Enterprise deployment requires performance benchmarking under live concurrent data streams, SSE topology updates reflecting dynamic network changes, and end-to-end latency characterization of the full epistemic control pipeline under production load conditions.

Dynamic Threshold Tuning: Current ECE and Brier Score gating thresholds are statically configured. Future iterations must implement adaptive threshold management incorporating UProp-derived trajectory uncertainty, threat landscape context (e.g., elevated thresholds during active campaigns), and analyst feedback loops for continuous threshold recalibration [19].

Ground Truth Temporal Delay: ECE and Brier Score require ground-truth outcome data for hypothesis calibration. In live SOC environments, ground truth may be delayed hours to days (investigation closure lag). The framework must incorporate temporal calibration windows and prospective UQ methods that do not require immediate ground truth [17].

Adversarial Robustness of UQ Mechanisms: The semantic firewall and taint-tracking defenses represent the current state of the art [4], but the Viral Agent Loop threat landscape will continue to evolve. Critically, the UQ mechanisms themselves must be audited for adversarial manipulation—an attacker who can influence ECE calculations or UProp estimates gains the ability to force ACT decisions through the gating mechanism, bypassing all epistemic controls.

6 Conclusion

This paper presents an Epistemic Decision Quality Framework for Security Operations Centers that addresses a measurable and growing failure mode: the deployment of uncalibrated, hallucination-prone autonomous AI in high-stakes security environments without commensurate epistemic oversight.

The case for intervention is quantitatively grounded: frontier models exhibit Expected Calibration Error (ECE) of 37–57% on expert-level benchmarks [1], hallucination rates of 15–52% in complex reasoning tasks [16], and are actively targeted by inference-time attacks that convert defensive agents into adversarial ones [4].

The framework responds through five integrated mechanisms—LLM hypothesis constraint, Agentic CRAG + FLARE active retrieval [9], formal Uncertainty Quantification via ECE, Brier Score, and UProp [19], Structural Simulation Engine (SSE) validation [2], and Zero-Trust Runtime Architecture [4]—governed by ISO/IEC 42001 compliant audit and governance controls [5].

The proof-of-concept demonstrates that epistemic controls reduce hallucinated reasoning to 3% and elevate the deferral rate to 22% in simulated workflows [15]: not a limitation of capability, but a confirmation of epistemic integrity.

Future priorities include longitudinal validation under live SOC conditions, adaptive threshold management integrating UProp, adversarial robustness testing of uncertainty quantification mechanisms, and the development of prospective UQ methods compatible with delayed ground-truth availability.

The question in 2026 is no longer whether AI can act at machine speed. It is whether the enterprise has constructed the mathematical, structural, and governance scaffolding necessary to trust it with that authority.

References

- [1] Scale AI. (2026). Humanity’s Last Exam (Text Only) Leaderboard. https://labs.scale.com/leaderboard/humanitys_last_exam_text_only
- [2] Chen, W. et al. (2026). AgentSOC: A Multi-Layer Agentic AI Framework for Security Operations Automation. arXiv:2604.20134.
- [3] HUMAN Security. (2026). The 2026 State of AI Traffic & Cyberthreat Benchmark Report.
- [4] Savyasachi, A. et al. (2026). Agentic AI as a Cybersecurity Attack Surface. arXiv:2602.19555.
- [5] KPMG International. (2026). ISO/IEC 42001: A New Standard for AI Governance.
- [6] Vectra AI. (2026). Modernizing SOC Operations with AI-Driven Detection.
- [7] ISC². (2025). Cybersecurity Workforce Study 2025.
- [8] Torq. (2026). Mastering SOC Automation in 2026.
- [9] Singh, R. et al. (2026). Agentic Retrieval-Augmented Generation. arXiv:2501.09136.
- [10] OWASP / Mend.io. (2025). LLM Security Risks and Mitigations.
- [11] Steyvers, M., Kumar, A. (2023). The Confidence-Competence Gap in LLMs. arXiv:2309.16145.
- [12] Phan, L. et al. (2026). HLE-Verified. arXiv:2602.13964.
- [13] IBM. (2026). Uncertainty Quantification.
- [14] Wang, Z. et al. (2026). Agentic Confidence Calibration. arXiv:2601.15778.
- [15] Sachania, D. H. (2026). Earning the Right to Act. Preprint.
- [16] SQ Magazine. (2026). LLM Hallucination Statistics 2026.
- [17] Ye, Z. et al. (2026). Uncertainty Quantification in LLM Agents. arXiv:2602.05073.
- [18] NeurIPS. (2025). Uncovering Confident Failures.
- [19] OpenReview. (2026). UProp: Uncertainty Propagation in LLMs.
- [20] Hevner, A. et al. (2004). Design Science in Information Systems Research.
- [21] Reason, J. (1990). Human Error.
- [22] SNSIN. (2026). SOC Metrics That Actually Matter.
- [23] Bayer, M. et al. (2026). Survey of Agentic AI and Cybersecurity.
- [24] Roff, H. M., Moyes, R. (2016). Meaningful Human Control.
- [25] NIST. (2023). AI Risk Management Framework.
- [26] Graylog. (2026). 2025 Security Trends.
- [27] ICLR Blogposts. (2025). Aleatoric vs Epistemic Uncertainty.
- [28] Microsoft. (2026). Trustworthy AI Agents with Foundry.
- [29] Lewis, P. et al. (2020). Retrieval-Augmented Generation. NeurIPS.
- [30] Bridewell. (2026). Addressing AI Hallucinations in SOCs.

This preprint is intended to contribute to ongoing research on trustworthy AI and security automation. Feedback, critique, and collaboration are welcomed.

Author Contact: drupad.h.sachania@live.com